J&J ACELERAÇÃO CYBERSECURITY

Segurança em Cloud: Redes e Perímetro

Fundamentos, arquitetura, controles e
e situações corporativas.



O perímetro em nuvem não é apenas uma barreira na borda: ele é distribuído entre recursos, redes, identidades, aplicações e dados.

Gemini Notebook

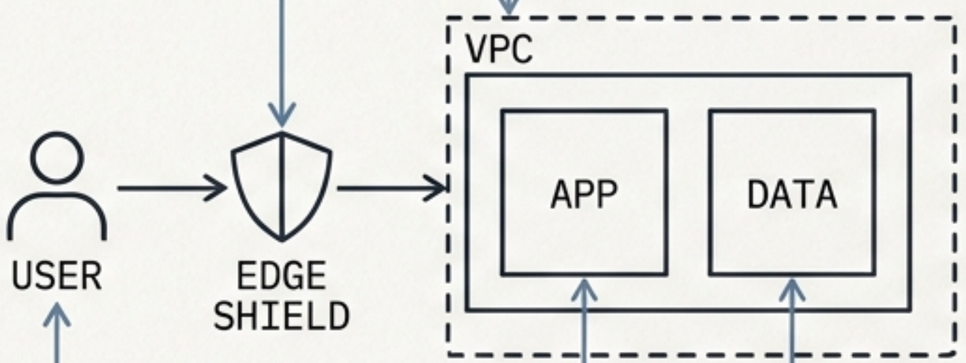
O Mapa do Perímetro: Arquitetura de Defesa em Cloud

Fundamentos e Topologia

- VPC/VNet e Sub-redes (isolamento lógico)
- Roteamento e Endereçamento (IPs públicos vs privados)
- Portas e Protocolos (`TCP 443`, `TCP 22`)

Borda e Trânsito

- WAF, DDoS, CDN e Balanceadores (linha de frente)
- DNS e TLS (integridade em trânsito)



Acesso e Identidade

- Conectividade Híbrida (VPN Site-to-Site)
- Zero Trust (verdade por contexto, não apenas rede)

Filtragem e Segmentação

- Firewalls (Stateful vs. Stateless)
- Security Groups, ACLs, NSG
- Microssegmentação e Menor Privilégio

Observabilidade e Governança

- Monitoramento Ingress/Egress e SIEM
- Ciclo de vida via IaC (Infraestrutura como Código)

Gemini Notebook

A Evolução do Perímetro: Do Físico ao Código



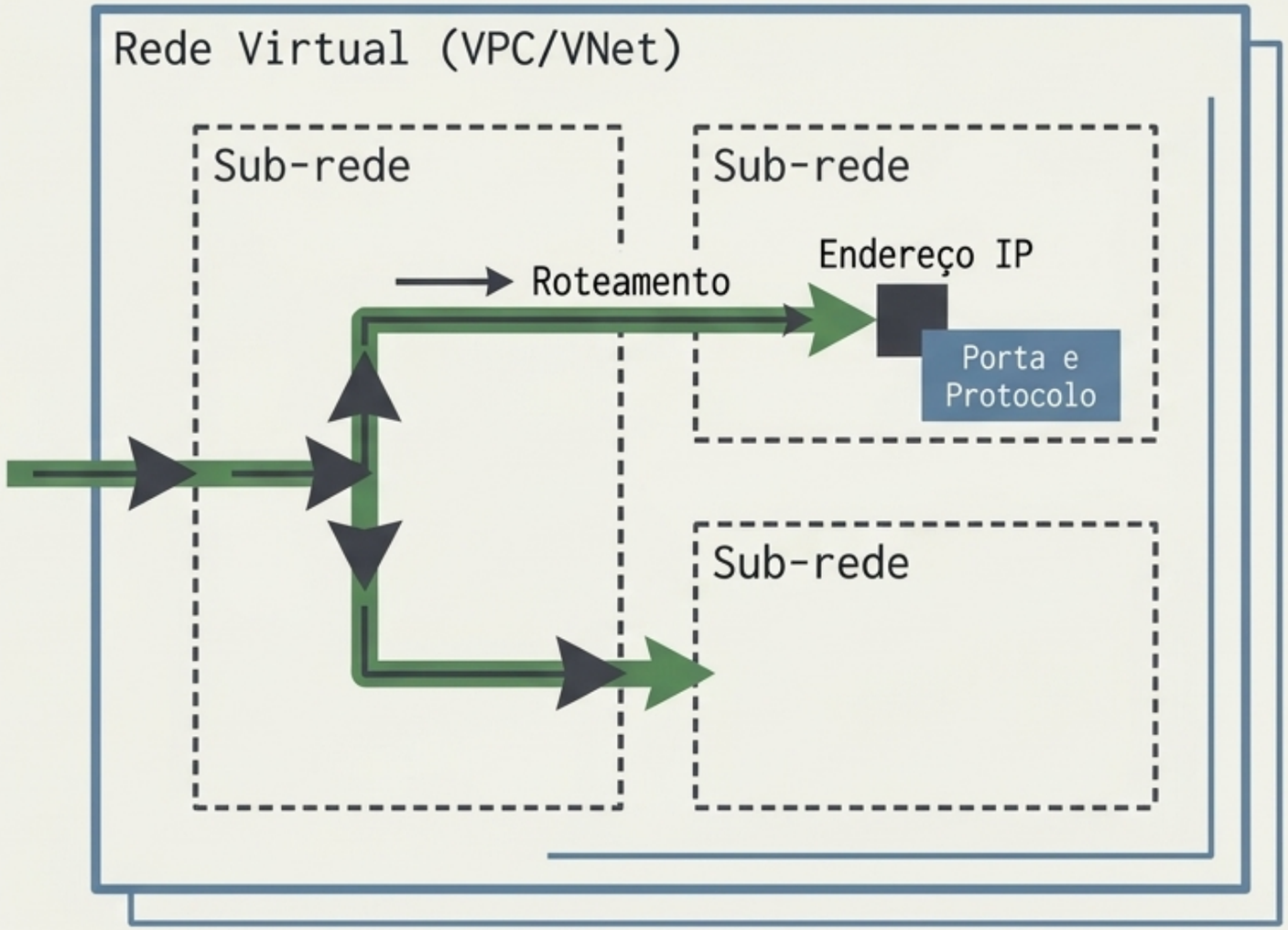


Datacenter Tradicional	Ambiente em Nuvem (IaaS/PaaS)
Infraestrutura Roteadores, switches e firewalls físicos.	**Infraestrutura** Redes virtuais, tabelas de rotas lógicas e políticas de acesso (Security Groups/NSGs).
Implementação Manual, dependente de cabeamento e hardware.	**Implementação** Configuração via consoles, APIs e IaC (Infraestrutura como Código). Conectividade criada em minutos.
Perímetro Focado em uma barreira de borda forte (o castelo).	**Perímetro** Distribuído e gerido por responsabilidade compartilhada (provedor cuida do físico; cliente projeta topologia e regras).

Gemini Notebook

Anatomia Lógica: Os Blocos de Construção da Rede

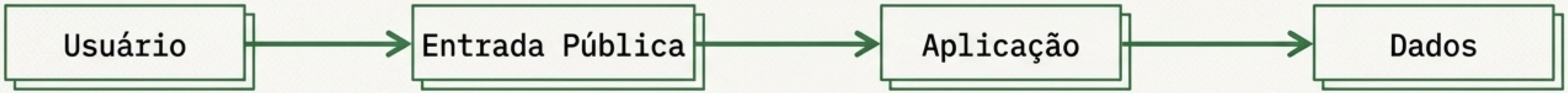
- **VPC/VNet**: Espaço lógico isolado para recursos da organização.
- **Sub-rede**: Subdivisão de IPs para separar funções, ambientes e níveis de exposição.
- **Roteamento**: Regras definindo o destino dos pacotes. **Atenção: rotas não são permissões irrestritas.**
- **Endereço IP**: Público (alcance via internet) vs. Privado (comunicação interna).
- **Porta/Protocolo**: Identificadores de serviços (ex: TCP 443/HTTPS).
- **Perímetro**: O conjunto sobreposto de controles restringindo movimentação entre zonas.



Gemini Notebook

Arquitetura Corporativa de Referência (3 Camadas)

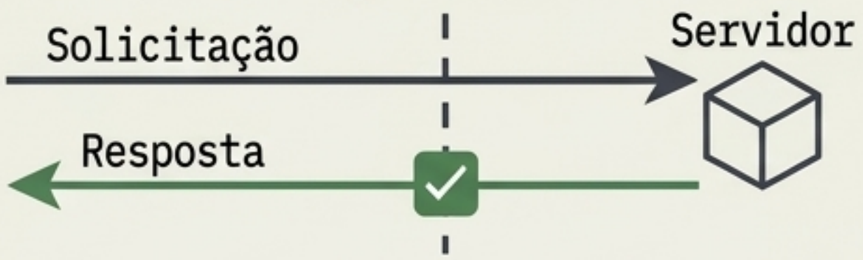
Zona	Recursos	Exposição Esperada
Entrada Pública	CDN, WAF, Balanceador de Carga	HTTPS para clientes externos. Ponto único de entrada.
Aplicação Privada (APIs)	APIs, serviços de negócio e lógica da aplicação	Somente origem expressamente autorizada (tráfego do balanceador).
Dados Privados	Bancos de dados, armazenamento	Somente comunicação da camada de Aplicação. Sem IP público.
Administração	Bastion hosts, VPN, ZTNA	Acesso restrito, autenticado e auditado. Sem acesso direto.



Gemini Notebook

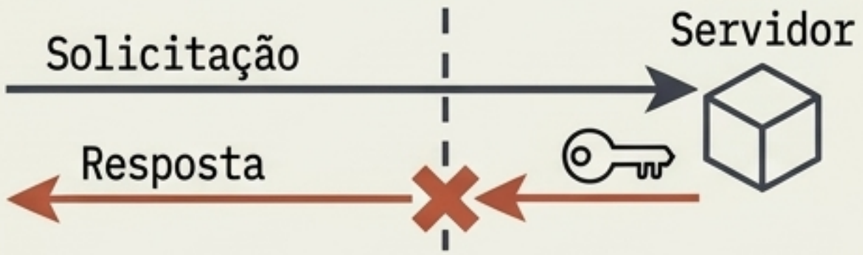
Filtragem de Tráfego: Controles Nativos e Estados

Stateful



Acompanha o estado da conexão. Permite automaticamente o tráfego de resposta.

Stateless

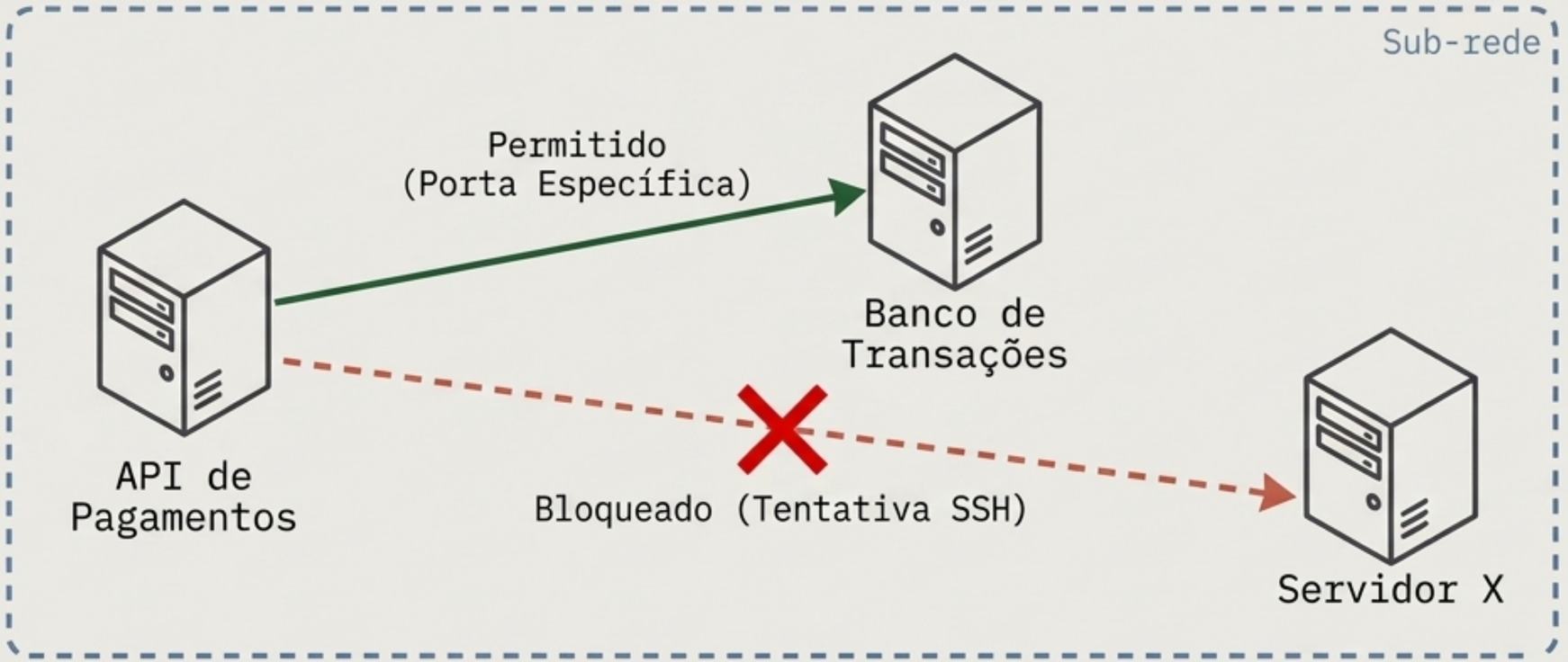


Avalia pacotes de forma independente. Exige regras explícitas para o tráfego de retorno.

Controle	Características e Boas Práticas
AWS Security Groups	Nível de recurso/interface. Stateful. Evitar 0.0.0.0/0 em portas administrativas.
AWS Network ACLs	Nível de sub-rede. Stateless. Considerar regras de ida e volta.
Azure NSG	Nível de sub-rede ou interface. Avaliar regras efetivas e prioridades.
GCP VPC Firewall	Controle entre recursos. Verificar escopo, prioridade e identidade.

Gemini Notebook

Segmentação e Microssegmentação



Conceito

Segmentar divide a rede em zonas (produção, dev). A microssegmentação aplica regras granulares entre aplicações dentro da mesma zona.

Menor Privilégio na Prática

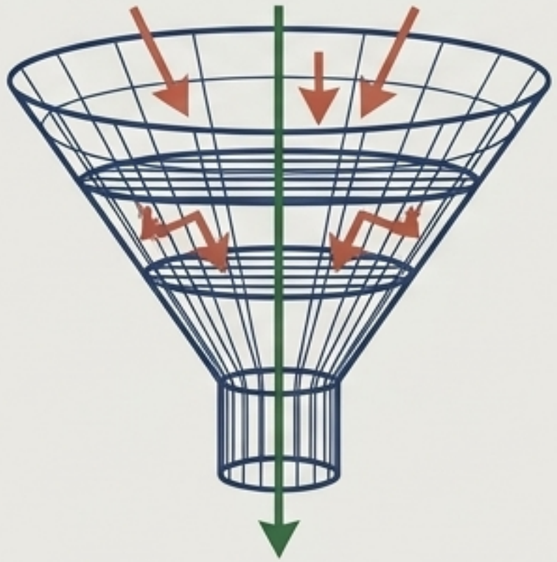
A API de pagamentos consulta o banco apenas na porta necessária. Ela é impedida de iniciar sessões SSH em outras máquinas, mesmo na mesma sub-rede, dificultando a movimentação lateral.

Gemini Notebook

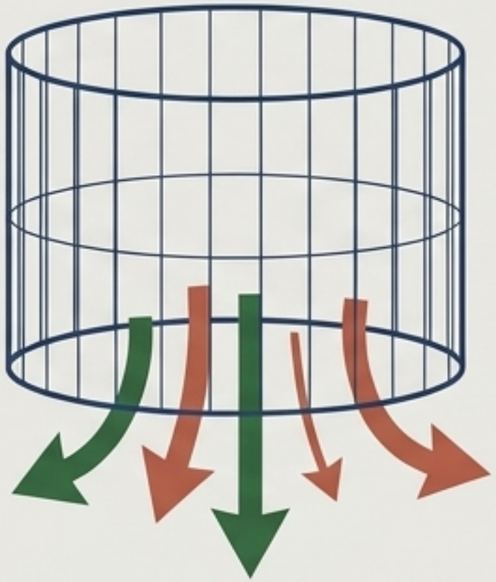
Tráfego Ingress vs. Egress: A Porta de Saída Esquecida

Empresas frequentemente protegem a entrada, mas uma aplicação comprometida usará a saída para exfiltrar dados ou contatar servidores C2 (Command & Control).

Ingress (Entrada)



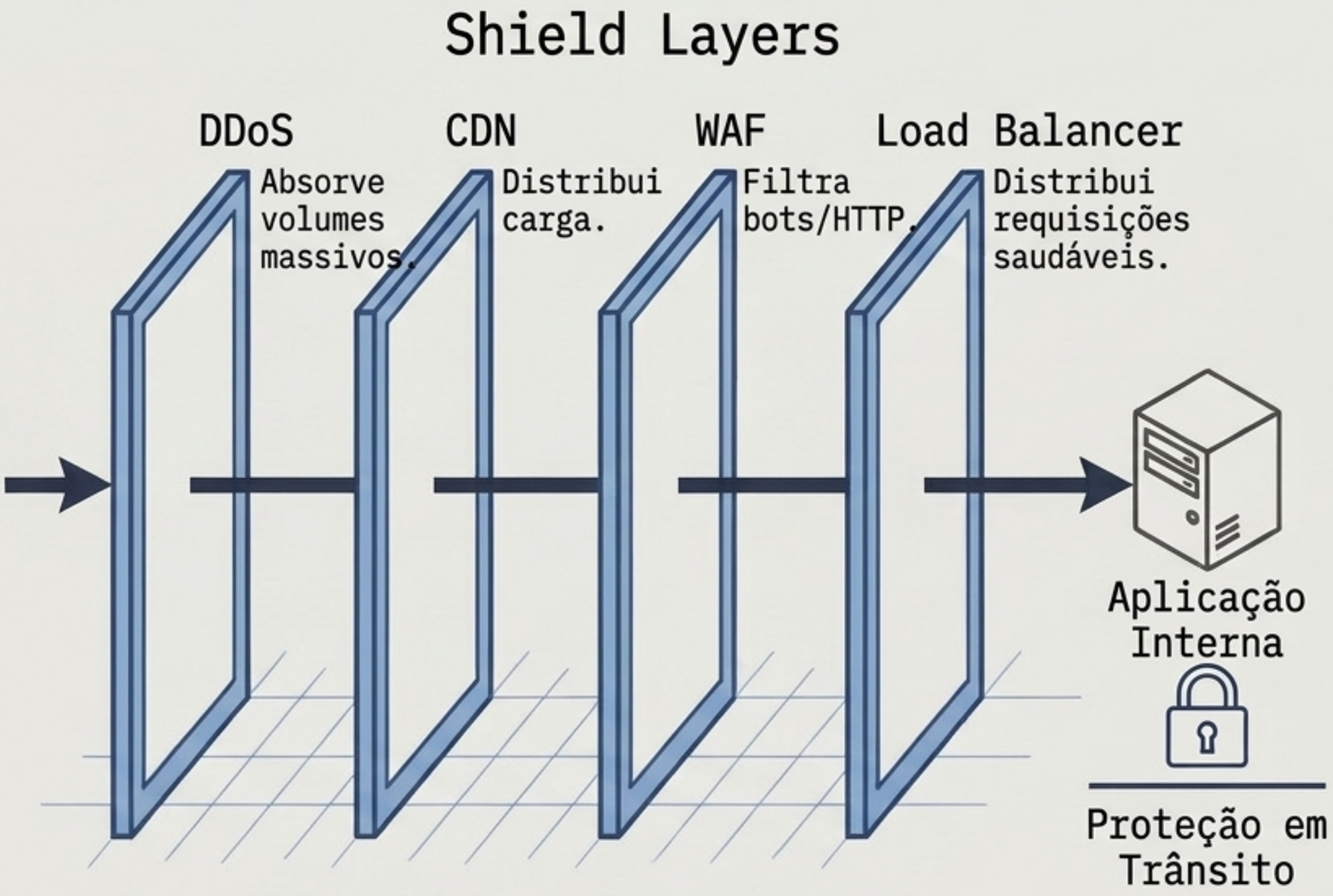
Egress (Saída)



- Permitir somente portas de entrada necessárias (HTTPS).
- Restringir acessos administrativos via contexto; nunca abertos à internet.
- Definir regras estritas de egress usando proxies e firewalls gerenciados.
- Utilizar endpoints privados para serviços, removendo tráfego da internet pública.

Gemini Notebook

Serviços de Borda e Proteção em Trânsito



Proteção em Trânsito

DNS

Traduz nomes em IPs. Erros de configuração podem expor origens que deveriam permanecer ocultas da internet pública.

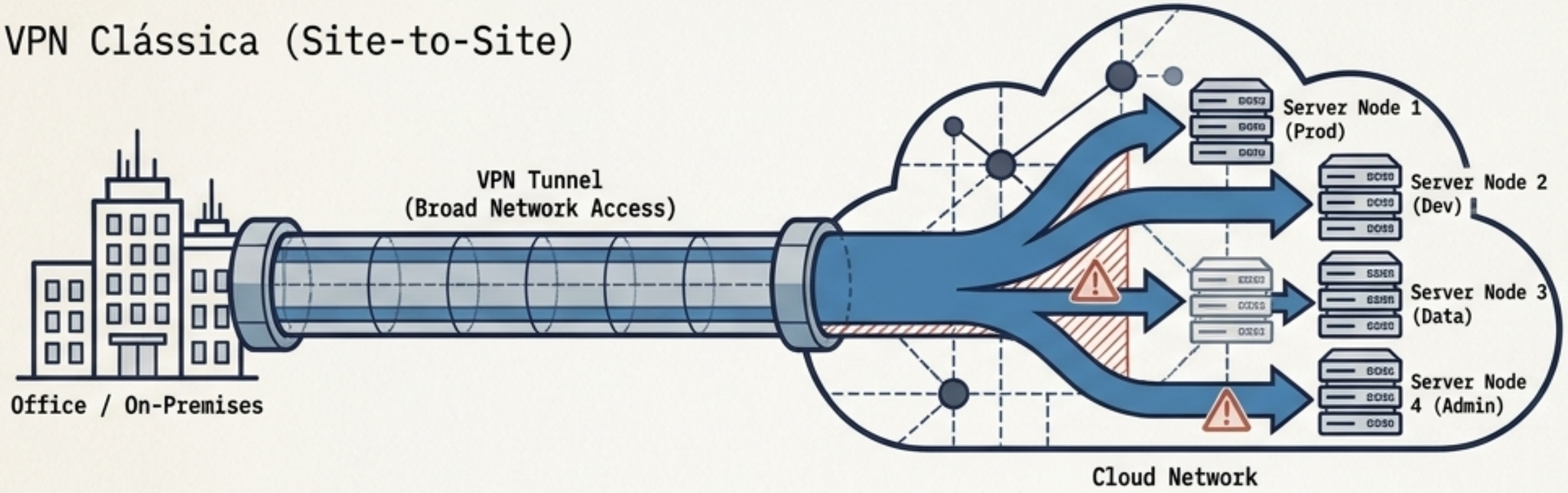
TLS (HTTPS)

Garante confidencialidade e integridade em trânsito. É crucial manter certificados válidos e proteger chaves privadas, mesmo para a comunicação estritamente interna.

Gemini Notebook

Conectividade Híbrida e a Abordagem Zero Trust

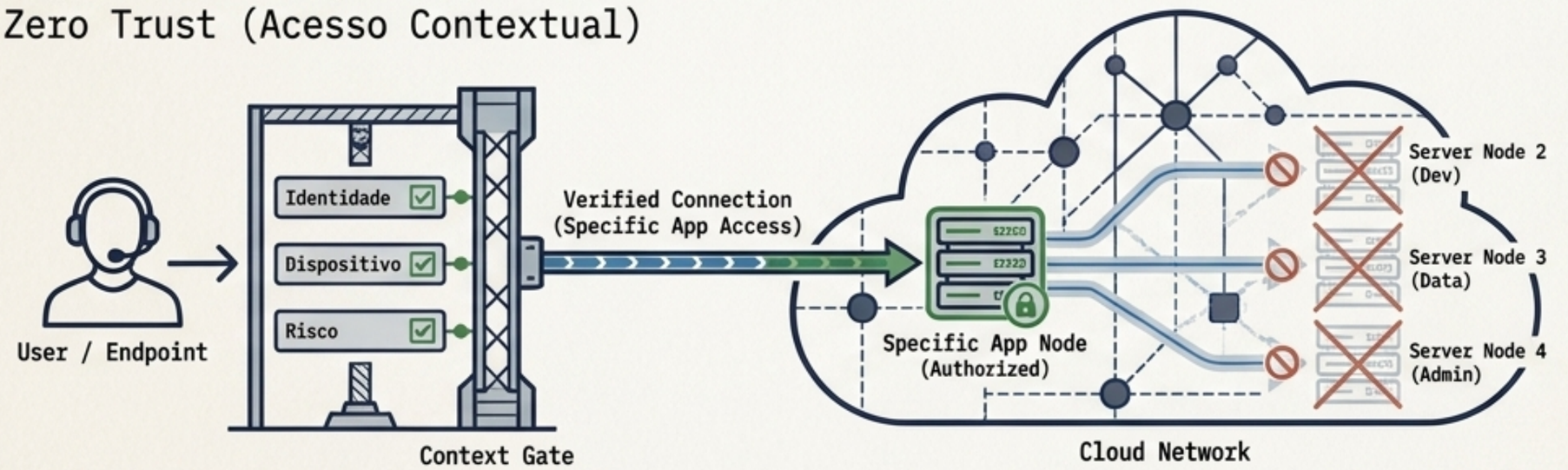
VPN Clássica (Site-to-Site)



O Risco: Roteamento amplo. Conectar à VPN não garante que o usuário deva ter acesso a todos os recursos. Uma rota excessiva amplia drasticamente o alcance de incidentes.

OVER-PRIVILEGED ACCESS, LATERAL MOVEMENT RISK.

Zero Trust (Acesso Contextual)



Exige verificação explícita contínua para cada acesso. Concede acesso apenas à aplicação específica autorizada, não à rede subjacente.

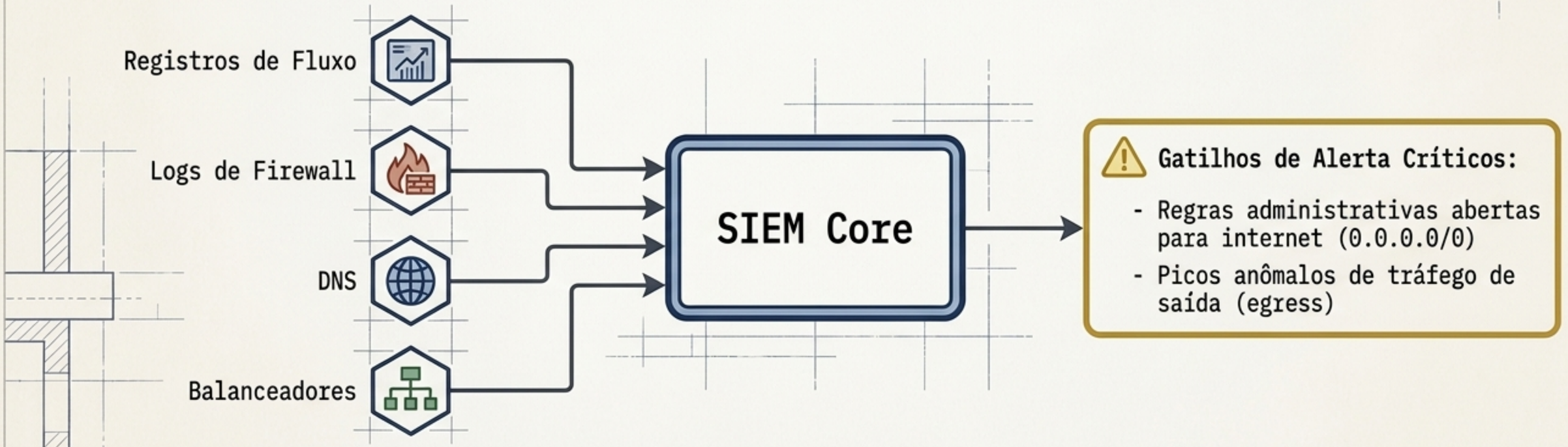
LEAST PRIVILEGE, CONTINUOUS VERIFICATION, MICRO-SEGMENTATION.

Gemini Notebook

Governança, Ciclo de Vida e Observabilidade

1. Solicitação
2. Análise de Risco
3. Aprovação
4. Implementação IaC
5. Testes
6. Monitoramento

Nota: Mudanças emergenciais exigem prazo, rastreabilidade e revisão posterior.



Gemini Notebook

Casos Reais: Diagnóstico e Resposta a Incidentes

Cenário de Ameaça	Falha Estrutural	Resposta Tática
Banco de Dados Exposto	IP público ativado e regra sem restrição de origem.	Restringir acesso, revisar logs, usar canal privado (Bastion).
SSH Aberto (Pós-Manutenção)	Exceção temporária na porta 22 sem expiração (0.0.0.0/0).	Remover regra, adotar MFA e processos IaC com alertas automáticos.
Movimentação Lateral	Ausência de microssegmentação após API comprometida.	Isolar carga, aplicar regras estritas de comunicação necessária.
Exfiltração de Dados	Falta de visibilidade e controle de tráfego Egress.	Investigar processo de origem, bloquear IPs de destino, revisar logs.
Ataque DDoS	Falta de resiliência na origem do site.	Ativar WAF/CDN, limitar requisições e acionar plano de continuidade.
VPN com Acesso Amplo	Confiar na rede como autorização geral para terceiros.	Segmentar acessos por função (MFA rigoroso), revisar rotas.

Gemini Notebook

Matriz de Decisão: Qual controle aplicar?

Necessidade de Negócio	Controle Técnico Recomendado
Publicar aplicação web	HTTPS, balanceador, WAF e proteção DDoS (conforme risco).
Isolar banco de dados	Sub-rede privada, regras restritivas e acesso estritamente interno.
Administrar servidores	Canal gerenciado (VPN/ZTNA), MFA obrigatório e auditoria de sessão.
Reduzir movimentação lateral	Segmentação de rede e regras baseadas na identidade da aplicação.
Detectar exfiltração de dados	Logs de fluxo ativados, alertas de tráfego egress e investigação SIEM.
Conectar escritório e nuvem	VPN site-to-site ou conexão dedicada (com rotas mínimas exigidas).

Gemini Notebook

O Checklist de Revisão de Segurança de Rede

Arquitetura e Exposição

- [ ] Todos os IPs públicos têm justificativa técnica e proprietário definido?
- [ ] As portas administrativas (SSH/RDP) estão fechadas para a internet?
- [ ] As bases de dados estão operando exclusivamente em zonas privadas?
- [ ] Existem regras específicas entre aplicações, em vez de permissões amplas?
- [ ] As conexões híbridas operam baseadas no princípio de menor privilégio?

Operações e Monitoramento

- [ ] As regras de tráfego de saída (egress) são conhecidas e monitoradas?
- [ ] Os logs de rede e de mudanças estão centralizados e retidos conforme política?
- [ ] Existem alertas automatizados para alterações perigosas e conexões anômalas?
- [ ] As exceções de firewall possuem prazo de expiração e rotina de revisão?
- [ ] A empresa testa periodicamente controles e os procedimentos de resposta?

Gemini Notebook

Referências e Padrões Fundamentais

NIST SP 800-207
Zero Trust Architecture.

NIST SP 800-53 Rev. 5
Security and Privacy Controls.

AWS
Amazon VPC User Guide & Security Best Practices.

Microsoft Learn
Azure Network Security Fundamentals.

Google Cloud
VPC Firewall Rules Architecture.

OWASP
Web Application Firewall Implementation.

J&J Aceleração Cybersecurity - Fim do Módulo.

Gemini Notebook